



ACTIVIDAD 01:

Análisis en grupo de un ciberataque real y su impacto empresarial.

Cyber ataque a PEMEX.

Profesor:

Servando López Contreras

Equipo 5:

Briano Montalvo Luis Enrique - 184914

Contreras Esparza Arturo - 184565

García Morales Alejandro-183793

Ortega Jiménez Juan Francisco - 184918

Gonzalez Diaz Aaron Emanuel - 182447

González Espinoza Karla Vanessa - 182928

Lizeth Infante Martínez - 18426



Índice

- 1** Introducción y Contexto General del ataque
- 2** Línea de tiempo
- 3** Tabla técnica del ataque
- 4** Tabla técnica del ataque
- 5** Evaluación del impacto (Modelo CIA)
- 6** Cálculo del costo total del ciberataque
- 7** Conclusión: Lecciones Aprendidas y recomendaciones

Introducción.



En noviembre de 2019, Petróleos Mexicanos (PEMEX), una de las empresas estratégicas más importantes del sector energético mexicano, sufrió un ciberataque mediante el ransomware DoppelPaymer. El incidente comprometió parte de su infraestructura corporativa de Tecnologías de la Información, provocó el cifrado de sistemas y estuvo relacionado con la extracción de información sensible. Aunque PEMEX informó que sus actividades de producción y abastecimiento continuaron operando, diversos procesos administrativos y equipos de cómputo resultaron afectados.

El caso resulta relevante debido a que investigaciones posteriores identificaron deficiencias previas de ciberseguridad, como sistemas operativos obsoletos, falta de actualización de parches y vulnerabilidades en servidores Microsoft SharePoint. El objetivo de este documento es analizar técnicamente el desarrollo del ataque, sus posibles vectores de entrada, las vulnerabilidades y fallas que facilitaron el incidente, así como sus consecuencias operativas, económicas y estratégicas.

1: Contexto general del ataque.

El día 10 de noviembre del 2019, México sufrió un ataque en uno de sus organismos más importantes: PEMEX (Petróleos Mexicanos).

PEMEX aseguró, ante la ola de desinformación y documentos apócrifos, que sus equipos de operación y producción se encontraban completamente blindados. La red interna de PEMEX, al igual que todas las grandes empresas e instituciones gubernamentales y financieras, nacionales e internacionales, recibe con frecuencia amenazas y ataques cibernéticos que al día de hoy no han prosperado.

DoppelPaymer tuvo distintos acercamientos, principalmente el spear phishing dirigido a los empleados, lo cual permitió el uso de diferentes técnicas como Drive-by Compromise (Técnica T0817). Esto les facilitó descargar software malicioso y la infección de documentos de Microsoft Office, los cuales comprometían los equipos de los empleados.

Linea de tiempo.

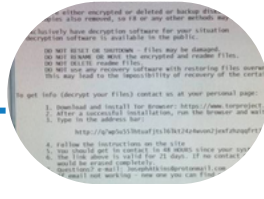


Notas:

- Durante la epoca del ataque el peso respecto al dolar solia tener un valor de **\$19.57**.
- Acorde a la pagina de **IBM OT** es la tecnologia utilizada para controlar, monitorear y automatizar dispositivos. (<https://www.ibm.com/mx-es/think/topics/ot-security>)
- **Dridex** tambien conosido como **evil corp** es un grupo criminal, hay un **virus troyano** del mismo nombre.



El ataque tuvo lugar el **10 de noviembre del 2019**, incidente comenzo cuando un empleado **descargo malware**, acorde a **CyOTE** el acercamiento inicial fue spearephishing.



Acorde a **CyOTE** los operadores de **Dridex** tambien pudieron tener un acercamiento inicial con:

DRIVE-BY COMPROMISE TECHNIQUE (T0817).

Acorde a **MITRE ATT&CK** esta tecnica coinsiste en que el usuario infecta su equipo con el simple echo de visitar una pagina web comprometida.

Los navegadores descargan sw malicioso haciendose pasar por actualizaciones del mismo.

Mediante el uso de otra tecnica **Modify Parameter T0836**, la infeccion continuo a más equipos de empleados.



Informacion **sensible** es filtrada a traves del sitio de **doppelpaymer**, ademas tambien es filtrada la configuracion **OT**.



Los atacantes exigen un pago de 565 bitcoin, equivalente a \$4,899,295.80 USD y a \$95,879,278.80 MX.



Tras escalar privilegios los atacantes desplegaron **doppelpaymer** un tipo de **ramsonware**.

El dia **11/11/2019** PEMEX afirma que la operacion y **produccion funciona con normalidad.**



2:Tabla tecnica del ataque.



Elemento	Descripcion
Tipo de Ataque	Se trató de un ataque de ransomware y extorsión cibernética de doble impacto, el cual combinó el cifrado masivo de sistemas de información con la exfiltración previa de datos sensibles
Actor o grupo Atacante	El incidente involucró a múltiples actores del cibercrimen organizados por etapas, incluyendo operadores de botnets (Emotet/Dridex), intermediarios de acceso inicial (Initial Access Brokers) y el grupo operador de DoppelPaymer.
Vector de entrada	El acceso se logró mediante campañas de spearphishing con archivos adjuntos de Microsoft Office infectados con macros, complementadas con drive-by compromise a través del marco FakeUpdates/SocGhoulish en sitios web comprometidos
Vulnerabilidad explotada	se explotó el factor humano mediante ingeniería social (interacción del usuario con alertas o macros engañosas), combinada con el robo y abuso de credenciales válidas.
Etapas del ataque	1) Acceso inicial 2) Ejecución y persistencia mediante scripts (VBA, JavaScript, PowerShell) 3) Movimiento lateral y escalada de privilegios con herramientas como Mimikatz y PoshC2 4) Exfiltración masiva de datos vía Rclone y Mega 5) Inhibición de mecanismos de seguridad, y 6) Impacto con el cifrado masivo de archivos (.doppeled) y despliegue de notas de rescate.

2:Tabla tecnica del ataque.



Elemento	Descripcion
Sistemas o servicios comprometidos	Los daños afectaron la infraestructura de red empresarial de Tecnologías de la Información de PEMEX, además de la exfiltración de información sobre arquitecturas de Tecnologías de la Operación. Además de afectar aproximadamente el 5% de sus equipos y 180,000 archivos
Duracion del incidente	Se estima una duración aproximada de dos meses, abarcando desde la infiltración inicial a principios de septiembre de 2019 hasta la detonación masiva el 10 de noviembre de 2019
Mecanismos de deteccion y respuesta	La detección se apoyó en el análisis de tráfico de red anómalo y registros en endpoints, mientras que la respuesta obligó a una desconexión de emergencia de sistemas y la adopción temporal de procesos operativos manuales

3: Evaluación del impacto (Modelo CIA).



Principio	Descripción del impacto	Evidencia del caso
Confidencialidad	Exfiltración sistemática y posterior divulgación en la Darknet de propiedad intelectual, esquemas de red industrial y credenciales corporativas tras negarse al pago del rescate.	Se exfiltraron alrededor 5.8 GB de datos comprimidos entre los que se encuentran manuales de control operativo y diagramas de arquitectura de red(INL, 2020), directorios con usuarios y contraseña de administradores de sistemas(ASF,2019).
Integridad	Alteración de sistemas de almacenamiento y destrucción de las capacidades de recuperación inherentes del sistema operativo.	Se cifraron columnes enteros de estaciones de trabajo(Mandiant,2020), se eliminaron permanentemente los Puntos de Restauración y las Copias de Sombra de Volumen antes del cifrado, lo que impidió la recuperación local(ESET Research, 2020).
Disponibilidad	Parálisis por aislamiento preventivo de la infraestructura de red corporativa, colapso de los portales de facturación comercial e interrupción en la logística de distribución.	Desconexión física y lógica de terminales administrativas a nivel nacional(European Union Agency for Cybersecurity., 2021), caída sistémica de los portales transaccionales de Pemex(Lakshmanan, R., 2019, noviembre 13)

4: Cálculo del costo total del ciberataque



Tipo de costo	Descripción	Estimación (MXN)
Perdidas operativas.	Días de inactividad, cancelación de operaciones o servicios.	\$383,500,000
Daños reputacionales.	Pérdida de clientes, caída en el valor de acciones, pérdida de la confianza.	\$50,000,000
Costos técnicos.	Recuperación de sistemas, consultorías externas, reemplazo de equipos.	\$95,600,000
Costos legales/regulatorios.	Multas, demandas o sanciones por incumplimiento (GDPR, ISO, etc.)	\$10,000,000
Pago de rescate o extorción.	En caso de ransomware, monto pagado o solicitado.	\$95,064,640
Total Estimado	Suma total en pesos mexicanos (MXN).	\$634,164,640

La conversión de dólares (USD) a pesos mexicanos (MXN) en el rubro emitido por el Banco de México (Banxico) correspondiente al año 2019, es de \$19.12 MXN por dólar.

Por otro lado, el costo total estimado del ataque que fue de casi \$634.2 millones pesos mexicanos con el presupuesto de Pemex. Según en la industria tecnológica de aquel año, la inversión específica destinada para el software y servicios de ciberseguridad rondaba los 80 millones de pesos. Esto significaba que el costo de recuperación e impacto del ransomware

DoppelPaymer fue casi 8 veces mayor que el presupuesto destinado a prevenirlo. Esto demuestra financieramente que la seguridad debe tratarse como una inversión crítica de infraestructura.

Conclusión: Lecciones Aprendidas y recomendaciones



Al analizar el caso, las fallas técnicas que facilitaron que el ransomware secuestrara miles de equipos principalmente fueron:

- Sistemas obsoletos, en específico más del 76% de los servidores comprometidos utilizaban versiones antiguas de Windows sin soporte
- Sin actualización a parches recientes de las vulnerabilidades en SharePoint, parches recientemente arreglados meses antes del ataque
- Carencias en los controles del ataque relacionados a inventario no actualizado con respecto al software autorizado y no autorizado, ausencia de agentes de protección avanzada y la escasa comunicación interna

Al tomar en cuenta dichas vulnerabilidades las medidas preventivas para mitigar el ransomware en resumen serían:

- Gestión en actualizaciones recientes y parches periódicos
- Controles técnicos básicos implementando agentes de protección avanzada, inventario y monitoreo continuo y pruebas de penetración regulares
- Capacitación en ciberseguridad y concientización contra phishing y malware

Normas y leyes aplicables al caso

- En cuanto al marco jurídico nacional en el ataque Pemex entraban a favor las siguientes leyes
 - a. Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP)
 - b. Ley de Seguridad Nacional

al no haber una ley específica para ciberseguridad, se recomendaría avanzar hacia una ley general de ciberseguridad, similar a la NIS Directive de la Unión Europea, que obligue a empresas críticas a cumplir estándares mínimos.

- Normas internacionales aplicables al caso:
 - a. ISO/IEC 27001 (gestión de seguridad de la información).
 - b. NIST Cybersecurity Framework (EE. UU.), aplicable como guía en Latinoamérica.
 - c. OEA – Estrategia Interamericana de Ciberseguridad, que promueve

Conclusiones finales:

El ataque a PEMEX en 2019 reveló graves fallas en la gestión tecnológica: sistemas obsoletos, falta de parches de seguridad y controles débiles de ciberseguridad, lo que expuso información sensible. Para prevenir incidentes similares se recomienda fortalecer los CERTs nacionales y regionales, establecer mecanismos obligatorios de reporte de incidentes y realizar auditorías externas en infraestructura crítica. En México y Latinoamérica, la adopción de marcos legales claros, estándares internacionales (ISO/IEC 27001, NIST CSF), instituciones sólidas y capacitación continua del personal son claves. El caso demuestra que la ciberseguridad debe ser parte esencial de la protección de la infraestructura crítica, no una reacción posterior a los ataques.

Bibliografía



Auditoría Superior de la Federación. (2019). Evaluación y Fiscalización de las Tecnologías de la Información y Comunicaciones de Petróleos Mexicanos (Auditoría de Desempeño Núm. 413, Informe Individual del Resultado de la Fiscalización Superior de la Cuenta Pública 2019). Cámara de Diputados.

https://www.asf.gob.mx/Trans/Informes/IR2019b/Documentos/Auditorias/2019_0413_a.pdf

Cybersecurity for the Operational Technology Environment (CyOTE). (2022, 31 de diciembre). Precursor analysis report: Doppelpaymer ransomware attack on Petroleos Mexicanos (PEMEX) 2019.

Centro de Estudios de las Finanzas Públicas. (2023). Indicadores Económicos de Coyuntura (Reporte basado en datos del Banco de México). Recuperado de <http://docencia.uaeh.edu.mx/estudios-pertinencia/docs/AGENDA%20ECONOMICA/Indicadores%20Economicos%20de%20Coyuntura%20III.pdf>

Computing. (2019, 18 de noviembre). La petrolera Pemex, víctima de un ransomware de 5 millones de dólares. Recuperado de <https://www.computing.es/noticias/la-petrolera-pemex-victima-de-un-ransomware-de-5-millones-de-dolares/>

CrowdStrike. (2019, 12 de julio). CrowdStrike Discovers New DoppelPaymer Ransomware & Dridex Variant. Recuperado de <https://www.crowdstrike.com/en-us/blog/doppelpaymer-ransomware-and-dridex-2/>

ESET Research. (2020). In-Depth Analysis of DoppelPaymer's Crypto-Routines, Process Termination, and System Recovery Sabotage. WeLiveSecurity. <https://www.welivesecurity.com/threat-research/>

European Union Agency for Cybersecurity. (2021). ENISA Threat Landscape: Ransomware Attacks on Critical Infrastructure. ENISA Publications Office. <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2021>

Idaho National Laboratory. (2020). Precursor Analysis Report: DoppelPaymer Ransomware Attack on Petróleos Mexicanos (CyOTE Case Study Series). Cybersecurity for the Operational Technology Environment (CyOTE) Program, U.S. Department of Energy. <https://www.osti.gov/biblio/1826042>

Instituto Mexicano para la Competitividad [IMCO]. (2023). Pemex en la mira: Resultados al cuarto trimestre. Recuperado de https://imco.org.mx/wp-content/uploads/2023/02/Pemex-en-la-mira_4T2022.pdf

Bibliografia



Lakshmanan, R. (2019, noviembre 13). Mexican State Oil Giant Pemex Hit by DoppelPaymer Ransomware Attack. The Hacker News.

<https://thehackernews.com/2019/11/pemex-ransomware-attack.html>

Mandiant. (2020). Big Game Hunting with DoppelPaymer: Lateral Movement, Evasion Techniques, and Volume Shadow Deletion. FireEye Mandiant Threat Intelligence Blog.

<https://www.mandiant.com/resources/blog/unc1151-and-doppelpaymer-tactics>

MITRE. (2025, 16 de abril). Drive-by compromise. MITRE ATT&CK. [<https://attack.mitre.org/techniques/T0817/>]

Mizzi, A. (2025). Diary of an IT Madman: A Story of Systems, Start-ups, and Surviving the Digital Revolution. Independently Published.

Petróleos Mexicanos, "Pemex opera con normalidad", Comunicado nacional 48, 11 nov. 2019. [En línea]. Disponible en: [https://www.pemex.com/saladeprensa/boletines_nacionales/Paginas/2019-47_nacional.aspx]

The Block. (2019, 14 de noviembre). Hackers demand \$5M in bitcoin from Mexico's national oil company Pemex. Recuperado de <https://www.theblock.co/news/ecosystems/2019-11-14-hackers-demand-5m-in-bitcoin-from-mexicos-national-oil-company-pemex-47099>